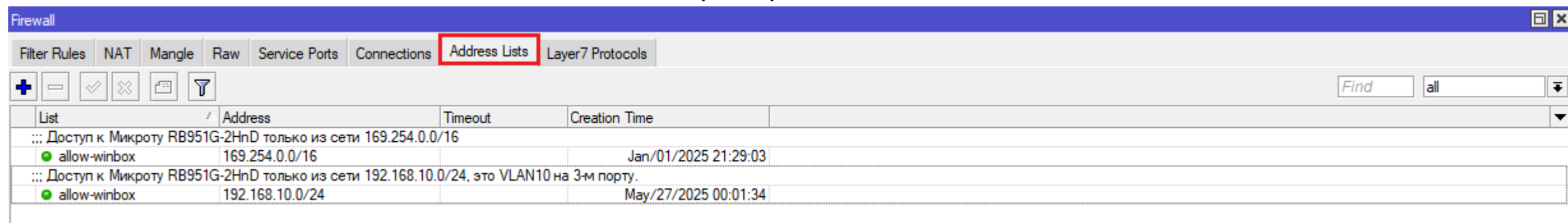


Как настроить защиту от брутфорса на Микротике RB951G-2HnD для Winbox и SSH по портам 8291 и 22 ?

- 1) Заходим в IP – Firewall – Address Lists.
- 2) Создаём Address Lists «allow-winbox».

Например, вот такой.



Таким образом, доступ к Winbox-у у нас будет только из этих двух подсетей.

- 3) Теперь заходим IP – Firewall – Filter rules.

----- Для начала, создадим правила для Winbox (8291). -----

1 Правило.

chain: input

Src. Address List [!] allow-winbox (т.е. все КРОМЕ allow-winbox)

Protocol: 6 (tcp)

Dst. Port: 8291

Connection State: [v] new

Action: add src to address list

Address List: winbox_stage1 (его не будет, его пишем руками)

Timeout: 00:01:00 (1 минута)

Комментарий: Кидаем все подозрительные попытки брутфорса на Winbox в winbox_stage1 на 1 минуту.

2 Правило.

Chain: input

Src. Address List: winbox_stage1

Protocol: 6 (tcp)

Dst. Port: 8291

Connection State: [v] new

Action: add src to address list

Address List: winbox_stage2 (его не будет, его пишем руками)

Timeout: 00:10:00 (10 минут)

Comment: Кидаем все подозрительные попытки брутфорса на Winbox в winbox_stage2 на 10 минут.

3 Правило.

Chain: input

Src. Address List: winbox_stage2

Protocol: 6 (tcp)

Dst. Port: 8291

Connection State: [v] new

Action: add src to address list

Address List: winbox_stage3 (его не будет, его пишем руками)

Timeout: 00:30:00

Comment: Кидаем все подозрительные попытки брутфорса на Winbox в winbox_stage3 на 30 минут.

4 Правило.

Chain: input

Src. Address List: winbox_stage3

Protocol: 6 (tcp)

Dst. Port: 8291
Connection State: [v] new
Action: add src to address list
Address List: winbox_blacklist (его не будет, его пишем руками)
Timeout: 10d 00:00:00
Comment: Кидаем все подозрительные попытки брутфорса на Winbox в winbox_blacklist на 10 дней.

5 Правило.

Chain: input
Src. Address List: winbox_blacklist
Protocol: 6 (tcp)
Dst. Port: 8291
Action: drop
Comment: Дропать всё, что попадает в winbox_blacklist и расценено как брутфорс-атака на сам Winbox по порту 8291.

Скриншот для наглядности.

Filter Rules																
NATMangleRawService PortsConnectionsAddress ListsLayer7 Protocols																
Reset Counters Reset All Counters Find all																
#	Action	Chain	Src. Address	Dst. Address	Src. Address List	Dst. Ad...	Protocol	Src. Port	Dst. Port	In. Interface	Out. Interface	In. Interface List	Out. Interface List	Bytes	Packets	
... Кидаем все подозрительные попытки брутфорса на Winbox в winbox_stage1 на 1 минуту.																
11	add src to address list	input			!allow-winbox		6 (tcp)		8291					0 B	0	
... Кидаем все подозрительные попытки брутфорса на Winbox в winbox_stage2 на 10 минут.																
12	add src to address list	input			winbox_stage1		6 (tcp)		8291					0 B	0	
... Кидаем все подозрительные попытки брутфорса на Winbox в winbox_stage3 на 30 минут.																
13	add src to address list	input			winbox_stage2		6 (tcp)		8291					0 B	0	
... Кидаем все подозрительные попытки брутфорса на Winbox в winbox_blacklist на 10 дней!																
14	add src to address list	input			winbox_stage3		6 (tcp)		8291					0 B	0	
... Дропать всё, что попадает в winbox_blacklist и расценено как брутфорс-атака на сам Winbox по порту 8291.																
15	drop	input			winbox_blacklist		6 (tcp)		8291					0 B	0	

Последнее правило (drop) идёт после правил с «add src to address list», так как сначала идёт оценка происходящего и небольшая блокировка на 1, 10 и 30 минут и, если атакующий не успокаивается, последним идёт бан на 10 дней.

----- Теперь, сообразим всё тоже самое, но для SSH (22). -----
Здесь всё по аналогии с Winbox (8291).

1 Правило.

chain: input

Src. Address List: [v] allow-winbox (т.е. все КРОМЕ allow-winbox)

Protocol: 6 (tcp)

Dst. Port: 22

Connection State: [v]

Action: add src to address list

Address List: ssh_stage1 (его не будет, его пишем руками)

Timeout: 00:01:00

Comment: Кидаем все подозрительные попытки брутфорса на SSH в ssh_stage1 на 1 минуту.

2 Правило.

chain: input

Src. Address List: ssh_stage1

Protocol: 6 (tcp)

Dst. Port: 22

Connection State: [v]

Action: add src to address list

Address List: ssh_stage2 (его не будет, его пишем руками)

Timeout: 00:10:00

Comment: Кидаем все подозрительные попытки брутфорса на SSH в ssh_stage2 на 10 минут.

3 Правило.

chain: input

Src. Address List: ssh_stage2

Protocol: 6 (tcp)

Dst. Port: 22

Connection State: [v]

Action: add src to address list

Address List: ssh_stage3 (его не будет, его пишем руками)

Timeout: 00:30:00

Comment: Кидаем все подозрительные попытки брутфорса на SSH в ssh_stage3 на 30 минут.

4 Правило.

chain: input

Src. Address List: ssh_stage3

Protocol: 6 (tcp)

Dst. Port: 22

Connection State: [v] new

Action: add src to address list

Address List: ssh_blacklist

Timeout: 10d 00:00:00

Comment: Кидаем все подозрительные попытки брутфорса на SSH в ssh_blacklist на 10 дней!

5 Правило.

chain: input

Src. Address List: ssh_blacklist

Protocol: 6 (tcp)

Dst. Port: 22

Action: drop

Comment: Дропать всё, что попадает в ssh_blacklist и расценено как брутфорс-атака на SSH по 22 порту.

Всё по аналогии. Последнее правило с drop-ом в конце.

Firewall															
Filter Rules NAT Mangle Raw Service Ports Connections Address Lists Layer7 Protocols															
+ - ✓ ✗ 📁 🔍 🔄 Reset Counters 🔄 Reset All Counters Find all															
#	Action	Chain	Src. Address	Dst. Address	Src. Address List	Dst. Ad...	Protocol	Src. Port	Dst. Port	In. Interface	Out. Interface	In. Interface List	Out. Interface List	Bytes	Packets
::: Кидаем все подозрительные попытки брутфорса на SSH в ssh_stage1 на 1 минуту.															
6	add src to address list	input			!allow-winbox		6 (tcp)		22					0 B	0
::: Кидаем все подозрительные попытки брутфорса на SSH в ssh_stage2 на 10 минут.															
7	add src to address list	input			ssh_stage1		6 (tcp)		22					0 B	0
::: Кидаем все подозрительные попытки брутфорса на SSH в ssh_stage3 на 30 минут.															
8	add src to address list	input			ssh_stage2		6 (tcp)		22					0 B	0
::: Кидаем все подозрительные попытки брутфорса на SSH в ssh_blacklist на 10 дней!															
9	add src to address list	input			ssh_stage3		6 (tcp)		22					0 B	0
::: Дропать всё, что попадает в ssh_blacklist и расценено как брутфорс-атака на SSH по 22 порту.															
10	drop	input			ssh_blacklist		6 (tcp)		22					0 B	0

Таким образом, если будет попытка брутфорс-атаки, злоумышленник сначала попадёт в бан на 1 минуту, затем на 10, затем на 30, а потом на 10 дней. Его IP адрес попадёт в динамически создаваемые адрес-листы. Вручную ничего заполнять не надо. Это сделано потому, что у атакующего, скорее всего, будут динамические IP и он, скорее всего, будет их время от времени менять, поэтому и адрес-листы у нас тоже динамические, чтобы подстроиться под атаку.